

CCNA 200-301 V2.0

25 Layer 2 Security

Part IV — Network Services and Security

EXAM TOPICS

4.7

LECTURER

Dr. Mustafa Hameed

THE ISLAMIA UNIVERSITY OF BAHAWALPUR

Department of Information Technology

What you will be able to do

- **Configure** port security with an appropriate maximum, learning method and violation mode.
- **Configure** DHCP snooping, and explain which ports must be trusted and why.
- **Configure** dynamic ARP inspection, including the case it cannot handle without help.
- **Configure** storm control and IPv6 RA guard.
- **Predict** the outage each of these causes when deployed carelessly — which is how they are examined and how they fail in practice.

Before we start

Chapter 3 for MAC learning. Chapter 8 for access ports. Chapter 20 — DHCP snooping is unintelligible without DORA. Chapter 5 for router advertisements, which RA guard exists to police.

Vocabulary for this chapter

port security

sticky MAC

violation mode

err-disabled

DHCP snooping

trusted port

binding database

dynamic ARP inspection

ARP ACL

storm control

RA guard

Each is defined where it first matters — not here.

Five named sub-topics, all configure

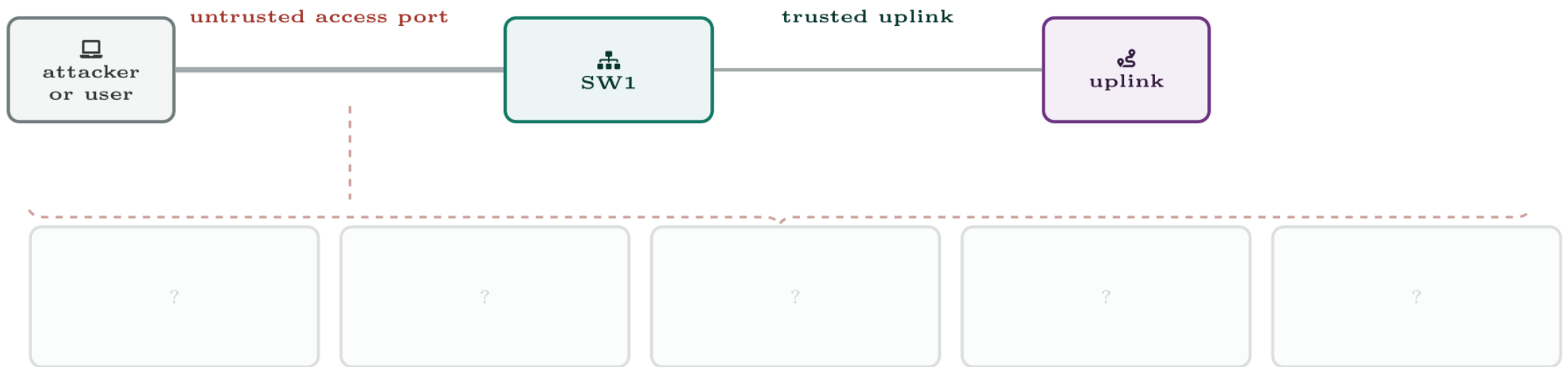
This is what the blueprint actually asks for

Topic **4.7** enumerates them: **4.7.a** DHCP snooping, **4.7.b** dynamic ARP inspection, **4.7.c** storm control, **4.7.d** RA guard, **4.7.e** port security.

Five features, one idea: **the access port is where the network meets people it does not control**, and each of these constrains one thing an attached device could otherwise do — claim many identities, answer as a DHCP server, lie in ARP, flood the segment, or claim to be an IPv6 router.

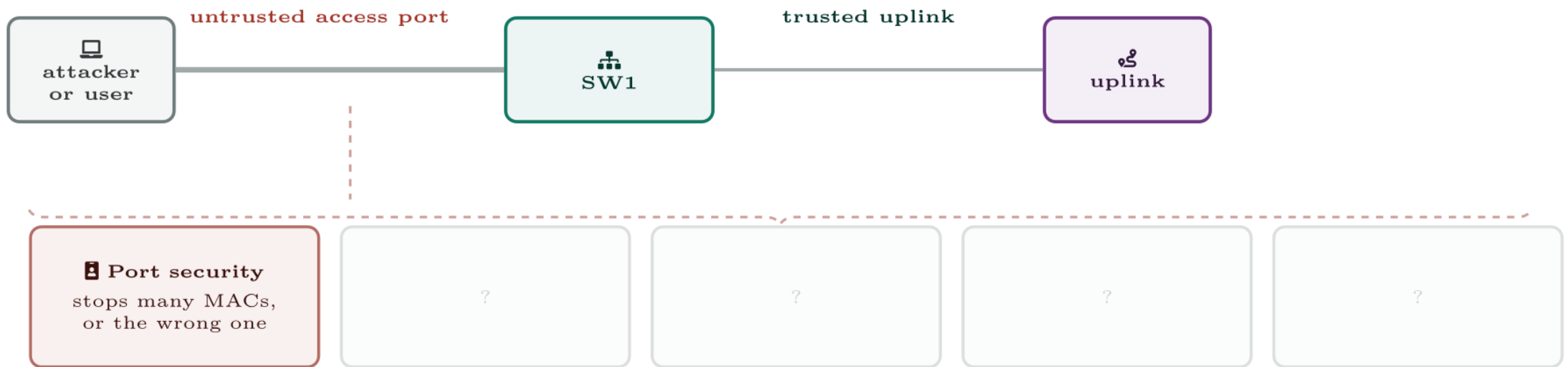
Learn them as that list of five abuses and the configuration follows.

Layer 2 Security



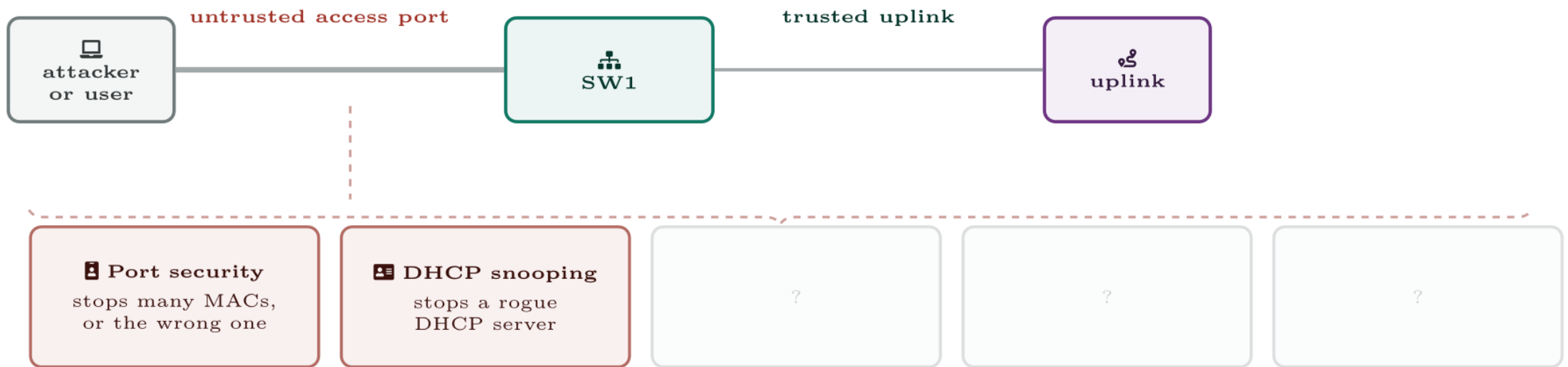
A host that sends thousands of source MACs fills the table and turns the switch into a hub. What stops it?

Layer 2 Security



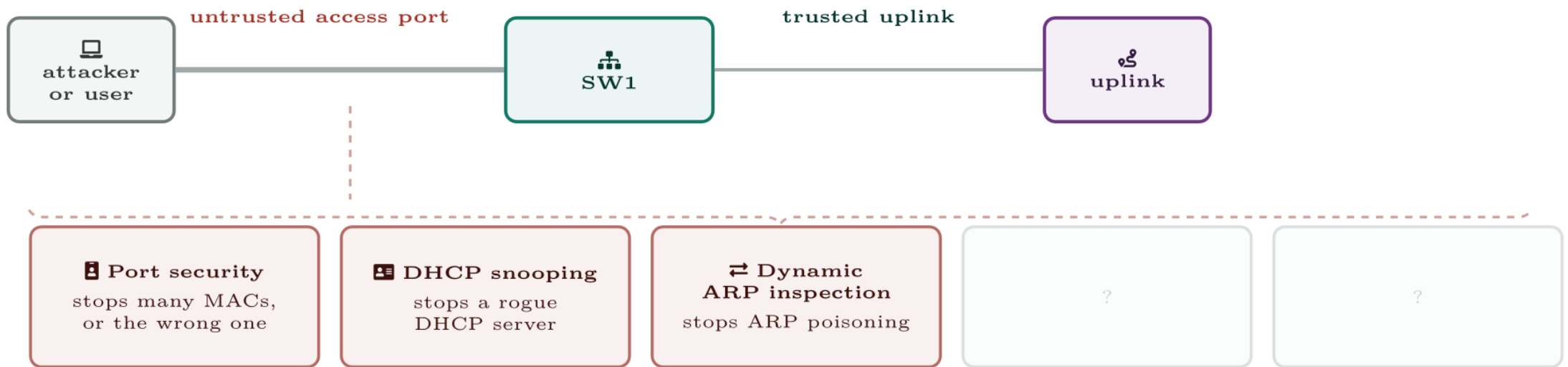
A laptop answering DHCP faster than the real server becomes the default gateway for the whole floor. What stops that?

Layer 2 Security



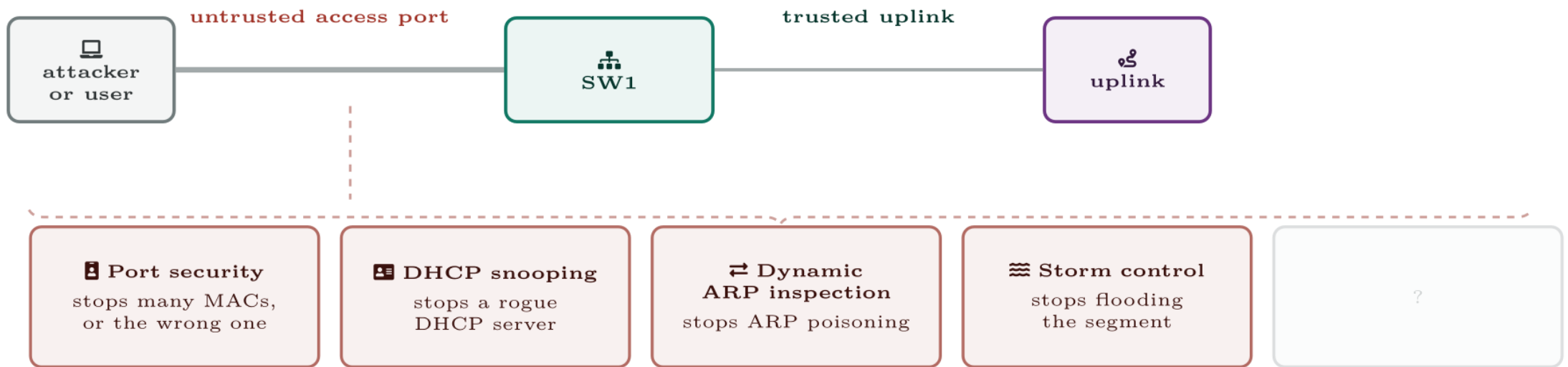
A host that answers ARP for an address it does not own then reads everyone's traffic. What stops that?

Layer 2 Security



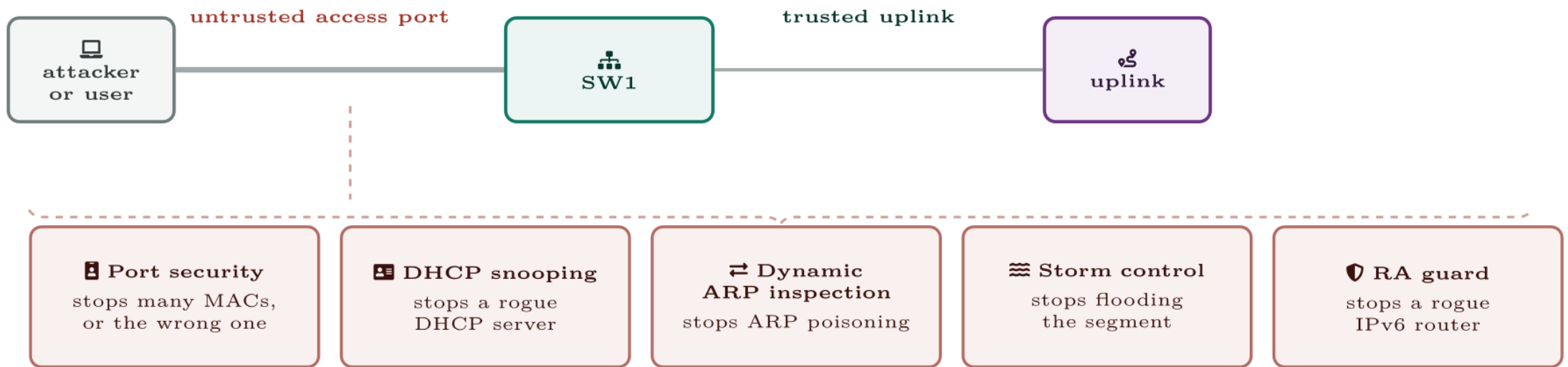
A loop, or one broken NIC, floods the segment until nothing else gets through.
What stops that?

Layer 2 Security



IPv6 hosts pick their router from an advertisement that anyone on the segment can send. And that one?

Layer 2 Security



Five features, five abuses, one port. All five live on the *access* port, and all five exist because the device plugged into it is not under your control.

Deploy them one at a time

This is what the blueprint actually asks for

Each of these can black-hole a floor on its own, and two of them — DHCP snooping and dynamic ARP inspection — will do so if the uplink is left untrusted. Turn one on, on one switch, and watch it before doing the next.

A normal user access port

IOS · configuration mode

```
interface GigabitEthernet1/0/5
  description Desk 5
  switchport mode access
  switchport access vlan 10
  spanning-tree portfast
  spanning-tree bpduguard enable
!
  switchport port-security
  switchport port-security maximum 2
  switchport port-security mac-address sticky
  switchport port-security violation restrict
  switchport port-security aging time 60
  switchport port-security aging type inactivity
```

switchport mode access must come first

Port security cannot be enabled on a port still in dynamic negotiation mode. If you type `switchport port-security` on a default port, IOS rejects it. Set the mode, then secure it — the same command-order rule as VLAN assignment in Chapter 8.

protect is a trap, and the exam knows it

It sounds like the gentle, sensible option. It is the one mode that gives you no evidence whatsoever: a user whose traffic is being silently discarded reports “the network is slow”, and nothing anywhere records why.

Prefer `restrict` when you do not want to drop the port, and `shutdown` when you do.

Automatic recovery after five minutes

IOS · configuration mode

```
errdisable recovery cause psecure-violation  
errdisable recovery cause bpduguard  
errdisable recovery interval 300
```


show port-security interface GigabitEthernet1/0/5

SW1#

```
Port Security           : Enabled
Port Status             : Secure-up
Violation Mode          : Restrict
Aging Time              : 60 mins
Aging Type              : Inactivity
Maximum MAC Addresses   : 2
Total MAC Addresses     : 2
Configured MAC Addresses : 0
Sticky MAC Addresses    : 2
Last Source Address:Vlan : 0050.7966.6800:10
Security Violation Count : 14
```

Sticky addresses are learned, not saved

`mac-address sticky` converts dynamically learned addresses into running-configuration entries. They are *not* written to the startup configuration until you save. Reload without saving and the port relearns whatever is plugged in at that moment — which may be the wrong device, now permanently authorised.

If you use sticky, `write memory` is part of the procedure, not an afterthought.

Trusted and untrusted

On an untrusted port, DHCP *server* messages (OFFER, ACK, NAK) are dropped. Client messages pass. On a trusted port everything passes.

Every port is untrusted once snooping is enabled on a VLAN. You must explicitly trust the path toward the legitimate server.

DHCP snooping on an access switch

IOS · configuration mode

```
ip dhcp snooping
ip dhcp snooping vlan 10,20,30
!
! Almost always required. The switch inserts option 82 into relayed
! requests; a router that is not configured to expect it discards the
! request, and every client fails. See the alert below.
no ip dhcp snooping information option
!
! The uplink carries the server's replies. Trust it.
interface GigabitEthernet1/0/48
  description Uplink to distribution
  ip dhcp snooping trust
!
! User ports stay untrusted, and are rate-limited so a single host
! cannot exhaust the pool by flooding requests.
interface range GigabitEthernet1/0/1-46
  ip dhcp snooping limit rate 10
```

The two faults that make snooping look broken

- **The uplink is not trusted.** The server's OFFER arrives on an untrusted port and is dropped. *Every* client on the switch fails, and the DHCP server logs nothing wrong because it answered.
- **Option 82.** By default the switch adds option 82 to requests it forwards, but with a `giaddr` of `0.0.0.0`. Cisco routers discard such packets unless told otherwise. Either `no ip dhcp snooping information option` on the switch, or `ip dhcp relay information trust-all` on the router.

Both produce the same symptom — a whole switch full of clients with no addresses, immediately after a change that “should have been transparent”.

show ip dhcp snooping binding

SW1#					
MacAddress	IpAddress	Lease(sec)	Type	VLAN	Interface
-----	-----	-----	-----	----	-----
00:50:79:66:68:00	192.168.10.21	27154	dhcp-snooping	10	GigabitEthernet1/0/5
00:50:79:66:68:22	192.168.10.22	27301	dhcp-snooping	10	GigabitEthernet1/0/7

The binding table is the point

Stopping rogue servers is useful. Building this table is what makes the next two features possible: it is the switch's record of *which MAC legitimately holds which IP on which port*. Dynamic ARP inspection and IP source guard both consult it.

So DHCP snooping is not an optional extra you turn on afterwards. It is the foundation, and it has to go first.

DAI on the same switch

IOS · configuration mode

```
! DHCP snooping must already be running on these VLANs.  
ip arp inspection vlan 10,20,30  
!  
! Optional but recommended: also check that the Ethernet header  
! addresses agree with the ARP payload, and that the IP is sane.  
ip arp inspection validate src-mac dst-mac ip  
!  
! Trust the uplink, exactly as for snooping. Switch-to-switch links  
! must be trusted or legitimate ARP is dropped between switches.  
interface GigabitEthernet1/0/48  
  ip arp inspection trust  
!  
! Rate-limit user ports. The default is 15 packets per second, and  
! exceeding it err-disables the port.  
interface range GigabitEthernet1/0/1-46  
  ip arp inspection limit rate 15
```


The case DAI cannot handle on its own

A statically addressed device — a server, a printer, a legacy controller — never asks for a DHCP lease, so it has **no entry in the binding table**. When DAI is enabled, its ARP replies match nothing and are dropped, and the device disappears from the network.

The fix is an ARP ACL naming the address and MAC explicitly:

Inventory your static devices *before* enabling DAI, not after the calls start.

show ip arp inspection statistics vlan 10

SW1#				
Vlan	Forwarded	Dropped	DHCP Drops	ACL Drops
----	-----	-----	-----	-----
10	88214	37	37	0

Storm control on user ports

IOS · configuration mode

```
interface range GigabitEthernet1/0/1-46
  storm-control broadcast level 5.00 3.00
  storm-control multicast level 10.00
  storm-control action trap
```

show storm-control broadcast

SW1#

Interface	Filter State	Upper	Lower	Current
-----	-----	-----	-----	-----
Gi1/0/1	Forwarding	5.00%	3.00%	0.42%
Gi1/0/7	Blocking	5.00%	3.00%	6.11%

RA guard on access ports

IOS · configuration mode

```
ipv6 nd raguard policy ACCESS-PORTS
  device-role host
!
ipv6 nd raguard policy UPLINKS
  device-role router
!
interface range GigabitEthernet1/0/1-46
  ipv6 nd raguard attach-policy ACCESS-PORTS
!
interface GigabitEthernet1/0/48
  ipv6 nd raguard attach-policy UPLINKS
```

Map each feature to the abuse it prevents

This is what the blueprint actually asks for

- **Port security** — one device claiming many MAC addresses, or an unauthorised device on a port.
- **DHCP snooping** — a rogue DHCP server handing out gateways.
- **Dynamic ARP inspection** — ARP poisoning, the on-path attack.
- **Storm control** — flooding, whether hostile or accidental.
- **RA guard** — a rogue IPv6 router. The v6 counterpart of DHCP snooping.

Matching questions on this list are close to free marks. Learn the five pairs.

Common pitfalls

- **Not trusting the uplink** for DHCP snooping or DAI. Takes out an entire switch.
- **Option 82 left on** with a Cisco relay that discards it. Same symptom, different cause.
- **Enabling DAI before inventorying static hosts.** Servers and printers vanish.
- **Port security maximum of 2 on a phone port.** Should be 3.
- **Using protect.** Silent drops and no evidence.
- **Sticky MACs never saved.** A reload re-learns whatever is plugged in.
- **no shutdown alone on an err-disabled port.** You must shutdown first.

Common pitfalls (continued)

- **Storm control with `action shutdown on user ports`.** Turns a transient into a truck roll.
- **Enabling everything at once on a Friday.** Each of these features can black-hole a floor. Deploy one at a time, on one switch, and watch.

After a security rollout, two servers and every printer stop responding. PCs are fine.

DHCP snooping and DAI were enabled across the access layer overnight. In the morning, all DHCP clients work normally — addresses lease, browsing works. But two application servers and every network printer are unreachable from everywhere, including from hosts in their own VLAN. The devices themselves are powered on, their link lights are up, and their switch ports show **connected**.

After a security rollout, two servers and every printer stop responding. PCs are fine.

What would you check first — and what do you expect to see?

show ip arp inspection statistics vlan 20

SW1#				
Vlan	Forwarded	Dropped	DHCP Drops	ACL Drops
----	-----	-----	-----	-----
20	4471	1902	1902	0

show ip dhcp snooping binding | include 192.168.20

What is the fault — and what does this output rule out?

Why it is doing that

Diagnosis. The binding query returns nothing for the server subnet. The servers and printers are statically addressed, so they never leased anything and never appeared in the snooping binding table.

DAI validates every ARP message on an untrusted port against that table. With no entry, every ARP reply these devices send is dropped — so no other host can ever resolve their MAC address, and they become unreachable while remaining perfectly healthy. The **DHCP Drops** column confirms it: 1902 packets dropped specifically for having no binding, and zero ACL drops because no ARP ACL exists.

Why it is doing that

Two details make the diagnosis clean. First, DHCP clients are unaffected — they have bindings, so this is not a general layer 2 fault. Second, the devices are unreachable *within* their own VLAN, which rules out routing entirely: ARP is the only thing that operates there.

An ARP ACL for the static estate

IOS · configuration mode

```
arp access-list STATIC-HOSTS
  permit ip host 192.168.20.15 mac host 0011.2233.4455
  permit ip host 192.168.20.16 mac host 0011.2233.4456
  permit ip host 192.168.20.30 mac host 00aa.bbcc.dd01
  permit ip host 192.168.20.31 mac host 00aa.bbcc.dd02
!
ip arp inspection filter STATIC-HOSTS vlan 20
```


And the lesson

Fix. Give the static devices explicit permission.

The process lesson. The rollout was not wrong, it was incomplete. DAI's dependency on the binding table is documented and predictable, and the work that was skipped was the inventory: every statically addressed device, its address and its MAC, before the feature is enabled. On a site of any size, the alternative is DHCP reservations for those devices instead, so that they build bindings like everyone else — which is the better long-term answer.

Securing an access switch, one feature at a time

Platform note. Packet Tracer supports port security, DHCP snooping, DAI and storm control. RA guard needs a real IOS image, so task 7 requires CML or GNS3.

Topology. SW1 with access ports in VLANs 10 and 20, an uplink to DSW1, a DHCP server beyond it, one statically addressed server in VLAN 20, a laptop you will use as the attacker, and an IP phone with a PC behind it.

1. Baseline: confirm every host has connectivity and can obtain a lease. Record the MAC address of every device — you will need them.
2. Configure port security on one access port with a maximum of 1 and `violation shutdown`. Move the cable to a second device and observe the err-disable. Recover it manually, then configure automatic recovery and repeat.
3. Set the phone port to a maximum of 2 and confirm the violation. Raise it to 3 and confirm it clears. Explain the third address.
4. Configure sticky learning, verify with `show run interface`, then reload *without* saving. Explain what you find.

Securing an access switch, one feature at a time (continued)

1. Attach the laptop running a DHCP server to an access port and confirm it can poison a client. Then enable DHCP snooping — **deliberately omitting** the trust on the uplink — and record the resulting symptom before fixing it.
2. Enable DAI. Confirm the statically addressed server becomes unreachable, diagnose it from `show ip arp inspection statistics`, and repair it with an ARP ACL.
3. Configure storm control at 1% with `action trap`, generate broadcast traffic, and watch the filter state change. Then change to `action shutdown` and compare the consequences.
4. **RA guard (CML).** Enable IPv6 on the VLAN, confirm hosts get addresses by SLAAC, then advertise a rogue prefix from the laptop. Observe the hosts move to it. Apply RA guard and confirm the rogue RAs are dropped.

Securing an access switch, one feature at a time (continued)

- 1. Extension.** Write the deployment runbook you would actually use for this rollout: the order, the pre-checks, what you would verify after each step, and the rollback for each.

CHECKPOINT 1 of 6

Name each of the five features and the specific abuse it prevents.

Discuss · then advance

Checkpoint 1 of 6

Name each of the five features and the specific abuse it prevents.

Port security — one device claiming many MAC addresses or an unauthorised device. DHCP snooping — a rogue DHCP server. Dynamic ARP inspection — ARP poisoning. Storm control — flooding. RA guard — a rogue IPv6 router.

CHECKPOINT 2 of 6

Why must DHCP snooping be configured before DAI, and what does DAI consult?

Discuss · then advance

Checkpoint 2 of 6

Why must DHCP snooping be configured before DAI, and what does DAI consult?

Because DAI validates ARP against the DHCP snooping **binding table**, which records which MAC legitimately holds which IP on which port. Without snooping running there is no table, and DAI has nothing to validate against.

CHECKPOINT 3 of 6

What is wrong with violation protect?

Discuss · then advance

Checkpoint 3 of 6

What is wrong with `violation protect`?

It drops offending traffic silently — no counter, no log, no trap. A user whose traffic is being discarded reports “the network is slow” and nothing anywhere records why. Prefer `restrict`, which drops and reports.

CHECKPOINT 4 of 6

Why is 3 the right port-security maximum on a port with a phone and a PC?

Discuss · then advance

Checkpoint 4 of 6

Why is 3 the right port-security maximum on a port with a phone and a PC?

Because the phone appears in the voice VLAN, the PC in the data VLAN, and the phone commonly registers a second address of its own. A maximum of 2 produces violations that come and go with phone firmware.

CHECKPOINT 5 of 6

A statically addressed printer stops responding after DAI is enabled. Explain the mechanism and give the fix.

Discuss · then advance

Checkpoint 5 of 6

A statically addressed printer stops responding after DAI is enabled. Explain the mechanism and give the fix.

It is statically addressed, so it never took a DHCP lease and has no entry in the snooping binding table. DAI therefore drops every ARP reply it sends, so nothing can resolve its MAC address and it becomes unreachable while remaining healthy. Fix with an ARP ACL naming its address and MAC, applied with `ip arp inspection filter`.

CHECKPOINT 6 of 6

Which two ports on an access switch almost always need to be trusted, and for which two features?

Discuss · then advance

Checkpoint 6 of 6

Which two ports on an access switch almost always need to be trusted, and for which two features?

The uplink toward the distribution layer, for **DHCP snooping** and for **dynamic ARP inspection**.
Untrusted uplinks take out the whole switch in both cases.

What to take away

- Five features, five abuses: port security (identity), DHCP snooping (rogue server), DAI (ARP poisoning), storm control (flooding), RA guard (rogue IPv6 router).
- Port security needs `switchport mode access` first. Maximum 3 for a phone plus PC. `restrict` for evidence without an outage, `shutdown` for enforcement, `protect` essentially never.
- Sticky addresses live in the running configuration only until you save.
- Recover an err-disabled port with `shutdown` then `no shutdown`, or configure `errdisable recovery`.
- DHCP snooping makes every port untrusted; trust the uplink, and expect to disable option 82 insertion.

What to take away (continued)

- Its binding table is what DAI validates against — which is why statically addressed devices need an ARP ACL.
- Storm control has a rising and a falling threshold; `trap` suppresses and reports, `shutdown` err-disables.
- RA guard classifies ports as `host` or `router` and drops RAs from hosts.

Where we got to

- Five features, five abuses: port security (identity), DHCP snooping (rogue server), DAI (ARP poisoning), storm control (flooding), RA guard (rogue IPv6 router).
- Port security needs `switchport mode access` first. Maximum 3 for a phone plus PC. `restrict` for evidence without an outage, `shutdown` for enforcement, `protect` essentially never.
- Sticky addresses live in the running configuration only until you save.
- Recover an err-disabled port with `shutdown` then `no shutdown`, or configure `errdisable recovery`.

NEXT

Chapter 26 — IPsec VPNs